

CVE-2025-15467

Cyber Threat Intelligence Case Study

Author: Leonard Okyere Afeke

Date: March 11, 2026

This report is based on publicly available information (OSINT) and controlled internal telemetry collected in a lab environment. No scanning, exploitation, or interaction with live systems occurred.

Executive Summary

CVE-2025-15467 is a stack buffer overflow in OpenSSL CMS AuthEnvelopedData AEAD parsing. The vulnerability affects all OpenSSL 3.x branches prior to their patched releases and may enable a crash or remote code execution when processing a specially crafted CMS object.

Testing on OpenSSL 3.0.2—part of the vulnerable 3.0.x branch—showed that malformed CMS samples did not trigger the overflow. OpenSSL 3.x enforces strict ASN.1 validation, causing malformed inputs to fail early and preventing the vulnerable IV-copying code path from being reached.

This report applies the Cyber Threat Intelligence (CTI) lifecycle to analyze OSINT, internal telemetry, exploitability, and defensive implications.

1 Key Judgments

- OpenSSL 3.0.2 is part of the vulnerable 3.0.x branch; the vulnerability is remediated only in version 3.0.19.
- Malformed CMS samples did not reach the vulnerable code path due to strict ASN.1 validation in OpenSSL 3.x.
- Exploitation requires a valid AEAD CMS object with an oversized IV; malformed CMS alone is insufficient.
- Telemetry collection confirmed full visibility into OpenSSL executions, arguments, and file interactions.
- Behavior observed on 3.0.2 generalizes to all affected 3.x branches.

2 Collection

OSINT Sources

- MITRE and NVD CVE entries
- OpenSSL security advisory
- Linux distribution advisories (Ubuntu, Debian, Fedora, SUSE)
- oss-security mailing list
- Patch commits across OpenSSL branches

Internal Telemetry

Telemetry was collected on an Ubuntu VM running OpenSSL 3.0.2 using Elastic Defend. Data sources included:

- process execution events

- file creation and access events
- ASN.1 parsing error output
- full process chains in Kibana Discover

3 Processing

OSINT and telemetry were normalized into structured fields.

OSINT Processing

- Vulnerability Type: Stack buffer overflow
- Component: CMS AuthEnvelopedData AEAD parsing
- Root Cause: Oversized ASN.1 IV copied into fixed-size buffer
- Affected Branches: 3.0.x, 3.3.x, 3.4.x, 3.5.x, 3.6.x
- Patched Versions: 3.0.19, 3.3.6, 3.4.4, 3.5.5, 3.6.1

Telemetry Processing

- All malformed CMS samples produced ASN.1 parsing errors.
- No crash or memory corruption occurred.
- No Elastic Defend rules triggered.
- OpenSSL executions were fully observable.

4 Analysis

Exploitability

OSINT indicates that exploitation requires:

- a valid AuthEnvelopedData CMS structure
- AEAD cipher parameters (e.g., AES-GCM)
- an oversized IV embedded in ASN.1 parameters

Malformed CMS samples did not meet these conditions and were rejected before reaching the vulnerable code path.

Environmental Relevance

OpenSSL 3.0.2 is widely deployed on Ubuntu systems. Although vulnerable, practical exploitation requires a highly specific CMS structure.

Adversary Behavior

An adversary would need to craft a valid AEAD CMS object and deliver it to an application that processes untrusted CMS data. This requires moderate cryptographic understanding.

5 Reporting

Impact Assessment

Technical Impact:

- Potential DoS or RCE if a crafted AEAD CMS object is processed.
- No crash occurred in testing due to early ASN.1 rejection.

Operational Impact:

- Applications parsing untrusted CMS data are at risk.
- Systems using OpenSSL 1.1.1 or 1.0.2 are not affected.

Detection Opportunities

Process-Level:

- openssl CMS operations
- AEAD-related arguments
- abnormal exit codes

File-Level:

- unexpected .cms file creation

Application-Level:

- service crashes or restarts
- ASN.1 parsing errors in logs

Mitigation

- Upgrade to patched branch releases:
 - 3.0.x → 3.0.19
 - 3.3.x → 3.3.6
 - 3.4.x → 3.4.4
 - 3.5.x → 3.5.5
 - 3.6.x → 3.6.1
- Restrict CMS parsing to trusted inputs.
- Monitor OpenSSL activity using process and file telemetry.

6 Conclusion

OpenSSL 3.0.2 is vulnerable to CVE-2025-15467 as part of the broader 3.0.x branch. However, malformed CMS inputs did not reach the vulnerable AEAD IV-copying code path due to strict ASN.1 validation in OpenSSL 3.x. Exploitation requires a highly specific, well-formed AEAD CMS structure.

Telemetry confirms that OpenSSL behavior is observable and provides actionable detection opportunities. Upgrading to patched branch releases remains the primary mitigation.